



Day 4: AWS Security Services & Compliance Frameworks

ITNW 1009 – Cloud Foundations | Securing the Perimeter

DAY 4 OF 5

CLOUD SECURITY

What We're Covering Today

Today you'll build a complete security toolkit — from blocking attacks at the edge all the way to proving compliance to auditors. These are the exact skills hiring managers look for in entry-level Cloud Operations roles.

01

Perimeter Defense

AWS Shield & AWS WAF — stop attacks before they reach your app

02

Continuous Monitoring

GuardDuty, Inspector & Macie — detect threats inside your environment

03

Compliance & Governance

AWS Artifact & Trusted Advisor — prove your posture to auditors

04

Unified Command

AWS Security Hub — one dashboard to rule them all

Learning Objectives

By the End of Today, You Will Be Able To...

1

Differentiate

Categorize AWS Shield Standard vs. Advanced and explain how AWS WAF filters at Layer 7

2

Select

Choose the right threat detection tool – GuardDuty, Inspector, or Macie – for a given risk scenario

3

Navigate

Use AWS Artifact to locate and download official compliance reports for auditors

4

Interpret

Read AWS Security Hub findings and explain what a security score means for an organization

Key Vocabulary

Terms You Need to Own

These words will appear on your AWS Certified Cloud Practitioner exam and in every cloud security job posting. Learn them cold.

DDoS

Distributed Denial of Service – flooding a server with fake traffic to knock it offline

WAF

Web Application Firewall – inspects HTTP requests at Layer 7 to block malicious code

CVE

Common Vulnerabilities & Exposures – the public catalog of known software security bugs

PII

Personally Identifiable Information – data like SSNs or credit cards requiring special protection

Compliance

Meeting industry regulatory standards such as HIPAA, PCI-DSS, and ISO certifications

What Is a DDoS Attack?

A **Distributed Denial of Service (DDoS)** attack sends a massive flood of fake traffic from thousands of compromised machines — all at once — to overwhelm your server until it crashes or becomes completely unavailable to real users.

⚠ The server isn't broken — it's just drowning. Real customers can't get through because every resource is consumed by fake requests.



AWS Shield: Your DDoS Defense Layer

Shield Standard

- **Free** — automatically enabled for every AWS customer
- Protects at **Layer 3 & 4** (network and transport layers)
- Filters volumetric floods, UDP amplification, and SYN floods
- Runs silently in the background — zero configuration required

Shield Advanced

- **Paid tier** — designed for high-stakes workloads (banks, e-commerce)
- 24/7 access to the AWS **Shield Response Team (SRT)** — real humans in a crisis
- Financial protection against bill spikes caused by attack traffic
- Enhanced DDoS visibility, metrics, and attack forensics

 **Exam Tip:** Shield Standard is free and automatic. Shield Advanced is paid and adds human expert support plus cost protection.



The Analogy

Shield = The Police Checkpoint on the Highway

AWS Shield Standard is like the default traffic lights and city police patrols that keep roads clear for everyone — already in place, always on, no charge. AWS Shield Advanced is like hiring a dedicated **elite riot-control squad** on standby 24/7 specifically for your building — they step in the moment a flash mob of fake customers tries to block your front door.

AWS WAF: The Web Application Firewall

While Shield blocks brute-force floods, **AWS WAF** stops the smart attacker who quietly slips malicious code into a web form. WAF operates at **Layer 7 (the Application Layer)** — it reads the actual content of every web request before it reaches your servers.



What WAF Inspects

HTTP headers, body content, query strings, and source IP addresses — line by line, on every request



Cross-Site Scripting (XSS)

Malicious JavaScript injected into web pages to hijack sessions or steal user credentials



SQL Injection (SQLi)

Attackers insert rogue database commands into form fields trying to dump or destroy your database



Web ACLs

You define Access Control Lists: allow clean traffic, block specific IP ranges or malicious patterns — instantly

The Analogy

WAF = The Sharp-Eyed Security Guard at the Door

Shield watches *how many* people are coming in. WAF watches *what they are carrying*.

This guard stands directly inside the revolving door and checks every visitor individually. If someone walks up with hidden lock-picks or a fake ID crafted to trick the front desk system, the guard **intercepts them immediately** – before they reach the elevator.

As a cloud support tech, deploying a single WAF rule at 10 PM can stop an active exploit and keep your company out of the headlines.



Shield vs. WAF — Side by Side

Choosing the Right Perimeter Tool

Attribute	AWS Shield	AWS WAF
OSI Layer	Layer 3 & 4 (Network / Transport)	Layer 7 (Application)
Threat Type	Volumetric floods, SYN/UDP amplification	SQL Injection, XSS, bad HTTP content
Cost	Standard = Free; Advanced = Paid	Pay per Web ACL and rule evaluated
Configuration	Standard is automatic; Advanced is opt-in	Manual rule setup via Web ACL console
Human Experts	Advanced only (SRT team)	No — rule-based automation



CHAPTER 2

Continuous Threat Detection

Perimeter defenses stop attackers at the gate — but what happens when a threat is already inside? The next three services watch your environment around the clock for anomalous behavior, software vulnerabilities, and exposed sensitive data.

Amazon GuardDuty: Your 24/7 Security Radar

Amazon GuardDuty is an intelligent threat detection service that continuously monitors your AWS account for suspicious and anomalous behavior – without touching your infrastructure or slowing down your workloads.



VPC Flow Logs

Traces all inbound and outbound network traffic across your virtual private cloud to detect lateral movement or data exfiltration



AWS CloudTrail Logs

Records every API call made in your account – GuardDuty spots unusual actions like a root account logging in from an unknown country



DNS Query Logs

Identifies instances communicating with known malicious domains – a classic sign of crypto-mining malware or command-and-control servers



GuardDuty reads logs **out-of-band** – it never installs an agent or adds overhead to your servers.

The Analogy

GuardDuty = The Plainclothes Detective in the Hallway



This detective doesn't stop people at the front door. Instead, they **watch behavior inside the building** all day long.

If a developer's EC2 instance suddenly starts communicating with a known cryptocurrency mining server at **3:00 AM**, GuardDuty triggers a high-severity alert. That behavior is abnormal — and GuardDuty is trained to know the difference.

Machine learning means it gets smarter over time, recognizing your environment's normal baseline and flagging deviations automatically.

AWS Inspector: Vulnerability Scanning Inside Your Servers

AWS Inspector looks *inside* your EC2 instances and container images to find the cracks in the walls before an attacker does. Think of GuardDuty as watching behavior – Inspector checks the physical structure.

EC2 Instances

Scans the software packages and libraries installed on your virtual machines for known CVE vulnerabilities

Container Images (ECR)

Evaluates Amazon Elastic Container Registry images for OS and application-level security flaws before deployment

Network Exposure

Flags accidental misconfigurations like an administrative port (SSH port 22) left open to the entire public internet

Remediation Blueprints

Provides a prioritized, step-by-step action list so an entry-level technician knows exactly what to patch and in what order

The Analogy

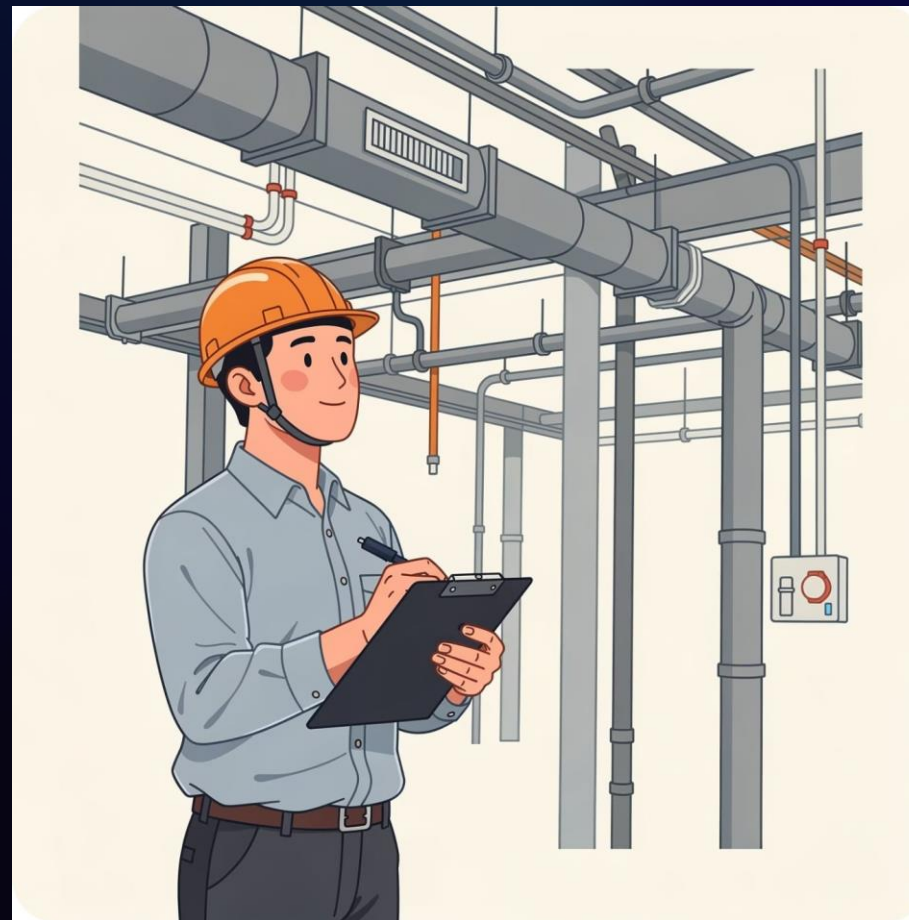
Inspector = The Licensed Building Safety Inspector

You hire a licensed structural inspector to walk through every room with a clipboard. They check if a back door was left unlocked by a maintenance worker, if a window latch is broken, or if the vault door has an **old lock that needs replacing**.

AWS Inspector does exactly this for your cloud servers. It walks through your operating systems, checks the software libraries, and hands you a prioritized report. For an entry-level technician, **that report is your daily task checklist**.

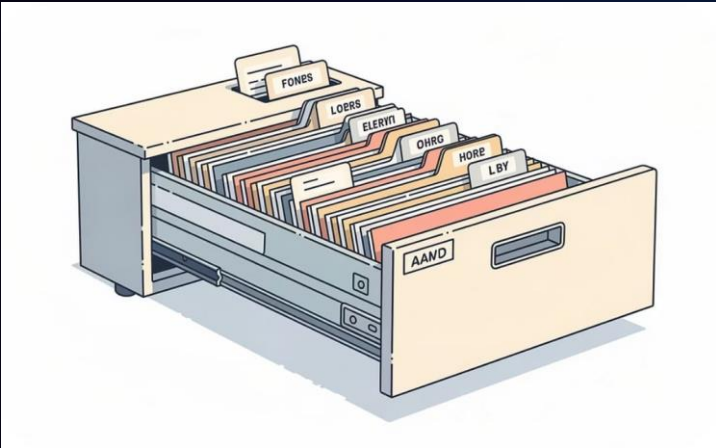


Quick Check: GuardDuty watches *behavior*. Inspector checks *vulnerabilities*. Both are essential — they're not the same thing.



Amazon Macie: Protecting Sensitive Data in S3

Amazon Macie uses machine learning to automatically scan your Amazon S3 storage buckets and find sensitive data that shouldn't be exposed — before a compliance disaster occurs.



Discovers PII Automatically

Macie recognizes Social Security Numbers, passport numbers, credit card numbers, API keys, and more — even buried inside large data files



Monitors S3 Bucket Exposure

Alerts you immediately if a bucket containing sensitive records is accidentally configured as publicly accessible — before a data breach occurs



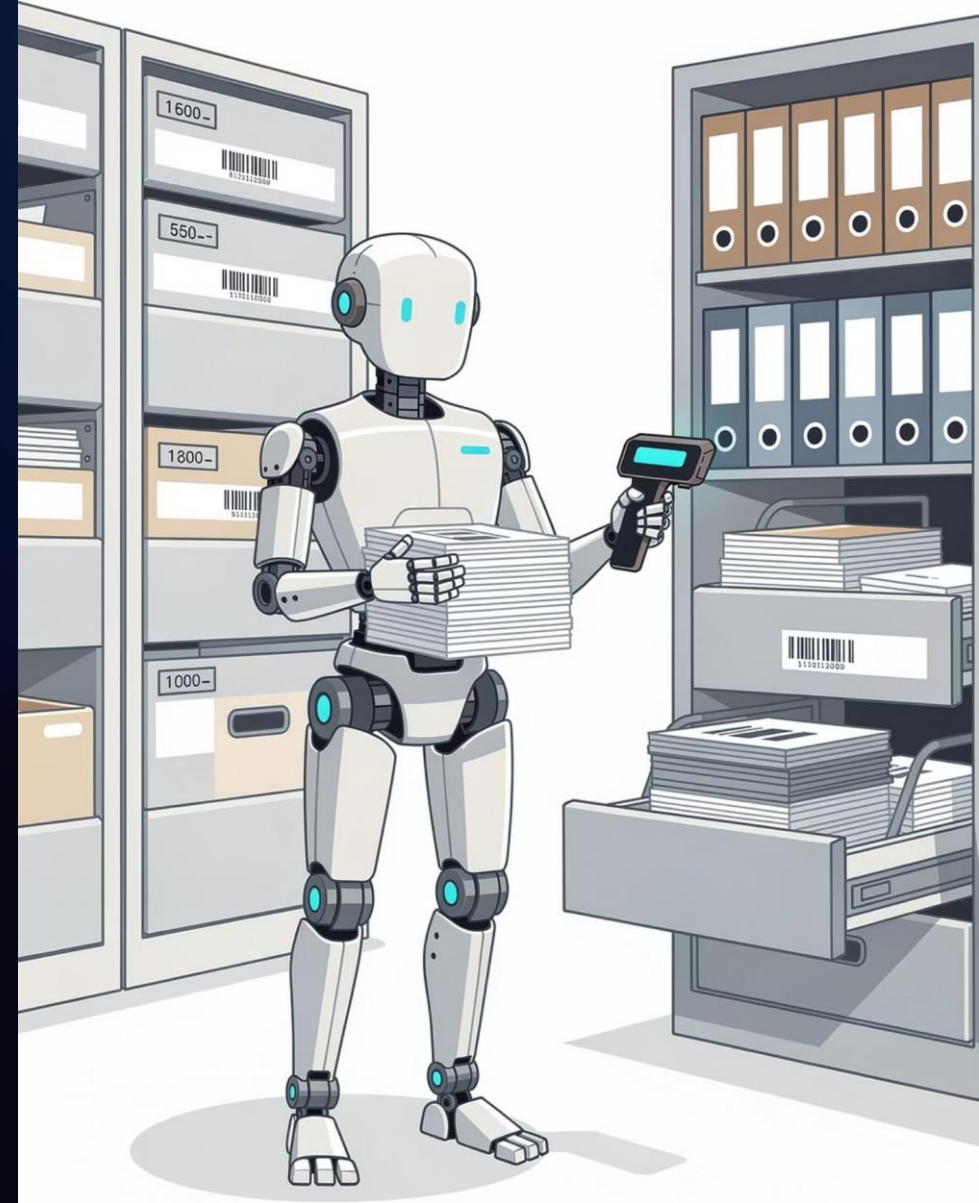
Automated Compliance Officer

Acts as a tireless digital auditor — continuously classifying data so your team always knows where sensitive information lives inside your storage environment

The Analogy

Macie = The Robot That Reads Every Filing Cabinet

Imagine a compliance robot that systematically opens every filing cabinet in your building, reads every document, and scans the contents. If it finds a folder of **customer credit card statements sitting on a public desk**, it flags it immediately so you can lock it away before anyone else sees it. Macie does exactly that — but across millions of files in seconds.



Detection Services — Side by Side

GuardDuty vs. Inspector vs. Macie

Attribute	GuardDuty	Inspector	Macie
What it monitors	Account behavior & network traffic	EC2 & container OS vulnerabilities	Sensitive data inside S3 buckets
Data sources	VPC Flow Logs, CloudTrail, DNS	EC2 agents, ECR image scans	Amazon S3 object content
Uses ML?	Yes — behavioral anomaly detection	CVE database matching	Yes — pattern recognition for PII
Primary output	Threat findings & severity alerts	Vulnerability report with patch steps	Data classification & exposure alerts



CHAPTER 3

Compliance & Governance

Detecting threats is half the job. The other half is **proving to regulators, auditors, and customers** that your cloud environment meets the standards they require. AWS Artifact and Trusted Advisor make compliance accessible to every team.

AWS Artifact: Your Compliance Document Portal

AWS Artifact is a free, self-service portal where you can download official AWS security and compliance documentation on demand — turning a months-long audit process into a simple file download.

SOC Reports

System and Organization Controls reports (SOC 1, 2, and 3) from independent third-party auditors validating AWS data center controls

ISO Certifications

International Organization for Standardization certificates covering security management, quality, and cloud-specific controls

PCI-DSS Compliance

Payment Card Industry Data Security Standard documentation — required for any business that processes credit card transactions

Legal Agreements

Review and accept AWS Non-Disclosure Agreements (NDAs) and Business Associate Addendums (BAAs) required for HIPAA-covered entities

The Analogy

Artifact = The Secure Vault of Building Certifications

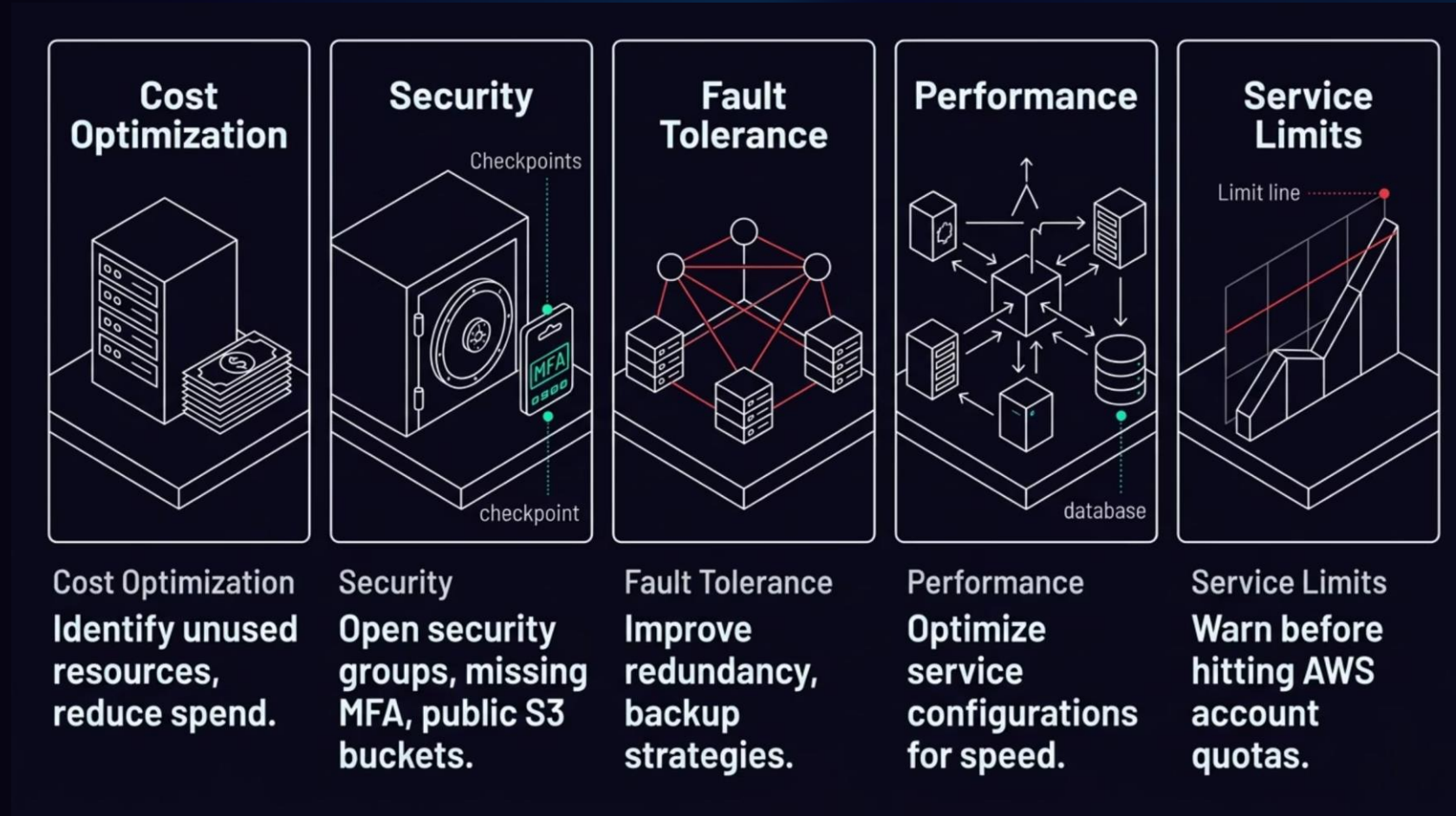


When a corporate client visits your building and says, *"Prove to me this facility is up to fire code and safety standards,"* you don't run a new inspection on the spot. You walk to the secure vault, grab the **pre-certified official copies**, and hand them over.

AWS Artifact works the same way. You don't rebuild the data center audit — you log in, navigate to Artifact, click download, and hand the PDF to your auditor. Your compliance obligation is met in minutes.

AWS Trusted Advisor: Your Automated Cloud Consultant

AWS Trusted Advisor scans your entire AWS account against best practices and gives you a color-coded health report across five critical pillars. Think of it as a consultant who's always watching your account — for free.



For today's lesson, the **Security pillar** is our focus — but remember all five for your Cloud Practitioner exam.

Reading the Trusted Advisor Dashboard

Trusted Advisor uses a simple, color-coded traffic-light system to communicate urgency. You don't need to be a senior engineer to understand your account health — it's designed to be readable at a glance.

Green — Pass

This check is configured correctly. No action needed. Your setting meets AWS best practice standards.

Orange — Investigate

Something looks off and warrants your attention soon. Not a crisis, but don't ignore it. Review and decide if action is needed.

Red — Act Now

Critical vulnerability or risk detected. Immediate remediation required.
Example: your root account has no MFA enabled, or a database is exposed to the public internet.

Real-World Trusted Advisor Findings

Security Checks That Save Companies Every Day

→ **Root Account Has No MFA**

The most powerful account in your AWS organization is unprotected. A single compromised password could mean total account takeover.

→ **Security Group Allows Unrestricted SSH Access**

Port 22 is open to 0.0.0.0/0 — meaning anyone on the internet can attempt to log in to your server directly.

→ **S3 Bucket Permissions Are Too Permissive**

A storage bucket is publicly accessible when it should be private — a common cause of massive data breaches at major companies.

→ **IAM Access Keys Not Rotated**

Programmatic credentials older than 90 days increase the risk of unauthorized access if the key was ever exposed in code or logs.

CHAPTER 4

One Dashboard to Rule Them All

When you're managing a real AWS environment, you can't check five different dashboards every morning. AWS Security Hub solves this with a single, unified security command center.



AWS Security Hub: Centralized Security Posture Management

AWS Security Hub is your single pane of glass for cloud security. It automatically collects, normalizes, and prioritizes security findings from across your entire AWS environment — so your team can focus on what matters most.



Aggregates All Findings

Pulls alerts from GuardDuty, Inspector, Macie, WAF, Trusted Advisor, and third-party tools into one normalized feed



Benchmarks Your Posture

Continuously measures your environment against CIS AWS Foundations Benchmarks and other industry security standards



Security Score (0–100%)

Gives your organization an overall security health score — leadership can see the big picture; technicians see the specific findings to fix



Automated Playbooks

Integrates with AWS Lambda and EventBridge to trigger automated responses to findings — reducing the need for manual intervention at 2 AM

The Analogy

Security Hub = The Airport Operations Control Center

What Feeds into Security Hub

- **WAF** – TSA checkpoint scanner results
- **Shield** – flight radar network perimeter alerts
- **GuardDuty** – concourse AI camera behavioral flags
- **Inspector** – aircraft maintenance diagnostic logs
- **Macie** – customs baggage scanner sensitive data hits

An airport's **Operations Control Center (AOCC)** consolidates every feed – TSA queues, radar, cameras, maintenance logs – onto a single screen matrix so the operations director sees the full picture at once.

Without the AOCC, a crisis in one terminal might go unnoticed because the manager is watching a different feed. Security Hub eliminates those blind spots for your AWS environment.

Complete Service Map

All 7 Services — Where They Fit



Every service has a distinct role — together they form a complete, layered defense strategy that mirrors how real enterprise security teams operate.



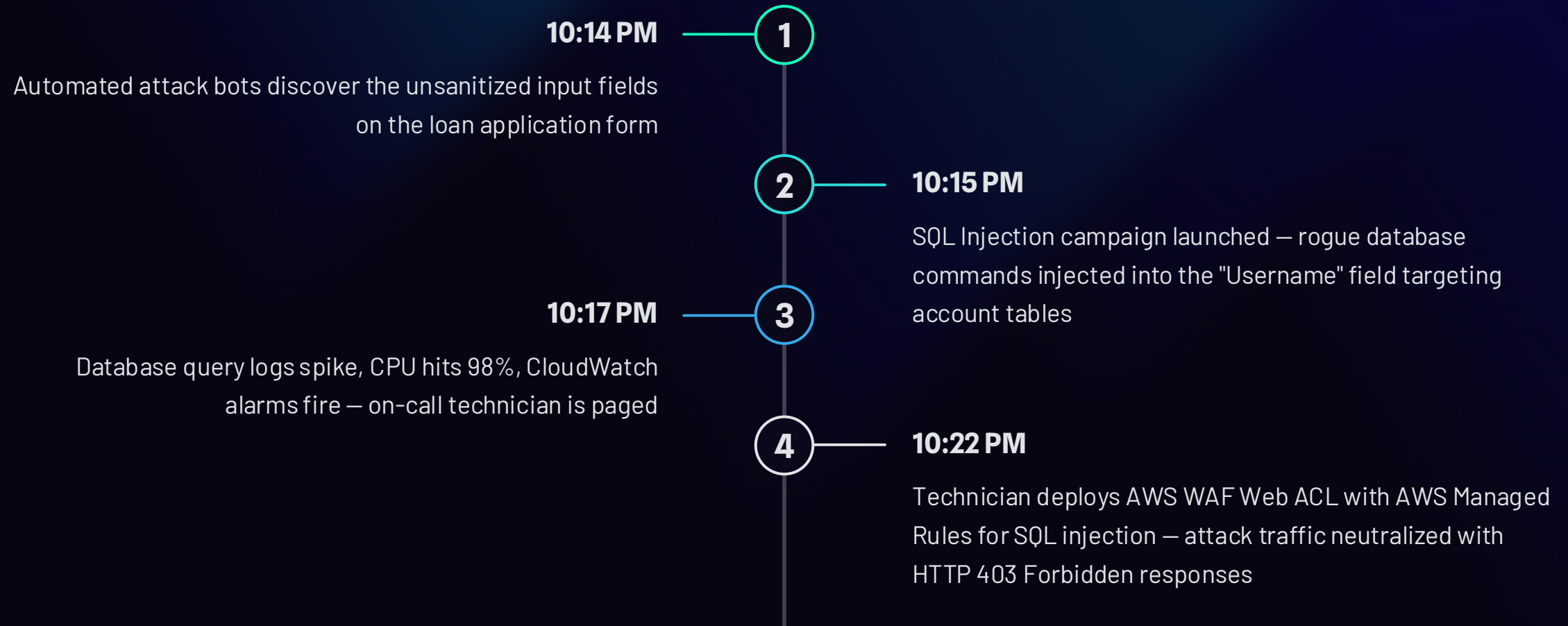
CASE STUDY

Vocational Case Study: Defending Apex Fintech

A real-world SQL injection attack, a junior technician, and a 10-minute response window. This is the scenario that tests whether your training translates to action.

The Incident: Friday Night at 10:14 PM

Apex Fintech is an emerging mobile app provider serving local credit union members. Their new loan application feature was rushed to launch without server-side input validation — leaving web form fields exposed to direct database manipulation.



The Response: WAF to the Rescue

What the Technician Did

1. Recognized the attack as a Layer 7 exploit – application code couldn't be patched quickly enough
2. Navigated to the AWS WAF console and created a new Web ACL
3. Attached the Web ACL directly in front of the Application Load Balancer
4. Enabled AWS Managed Rules for known database exploits (SQLi set)
5. Within seconds, WAF began inspecting packets and dropping malicious requests with **HTTP 403 Forbidden**

The Outcome

The attack traffic was **neutralized at the perimeter**. The core database servers remained safe. No customer financial data was exfiltrated. A catastrophic compliance breach was prevented – by one junior technician, in under ten minutes. This is exactly why we train for these scenarios.

Critical Thinking: Discussion Questions

Think through these questions before the debrief. These aren't trick questions — they test whether you can apply today's tools to real situations, which is exactly what interviewers will ask you.

1

WAF vs. Code Fix?

Should Apex permanently rely on WAF rules to block these attacks, or is code refactoring required? Defend your answer from a cost and long-term security standpoint.

2

Automation?

A human had to manually log in at 10:14 PM to deploy the WAF rule. How could AWS GuardDuty, Security Hub, and Lambda be combined to automate this response?

3

Bypass Scenario?

If the attacker used encrypted, obfuscated SQL injection strings that bypassed WAF rules, which secondary AWS service would detect abnormal behavior from the compromised EC2 instance?

Model Answer Rubric: What a Strong Response Covers

1 Root Cause Identification

The vulnerability is a **Layer 7 application flaw** — unsanitized input fields processed user text as raw database commands. WAF is a tactical stop-gap, not a permanent fix.

2 Defense-in-Depth Posture

WAF buys time while developers refactor the code. Long-term security requires **both layers**: perimeter WAF rules AND proper server-side input validation.

3 Automation Integration

GuardDuty → **Security Hub** → **Lambda** can detect anomalous behavior and trigger a WAF rule update automatically — eliminating the 3 AM manual response requirement.

4 Layered Architecture

If WAF is bypassed, **Amazon GuardDuty** provides the secondary defense layer by monitoring VPC Flow Logs and CloudTrail for abnormal outbound communication from compromised hosts.

AWS CCP Exam: What You Must Know Cold

The AWS Certified Cloud Practitioner exam tests recognition and differentiation – not deep configuration. Here are the highest-frequency topics from today's lesson.



Shield = Free + Automatic

Standard requires zero configuration. Advanced adds SRT access and cost protection.



WAF = Layer 7 Rules

The only service that inspects HTTP content. Configured via Web ACLs. Blocks SQLi and XSS.



GuardDuty = Behavior Watch

Reads logs out-of-band. No agents. Detects crypto-mining, unusual API calls, malicious IPs.



Inspector = Patch Scanning

Finds CVEs inside EC2 and container images. Gives you a prioritized remediation checklist.



Macie = PII in S3

Uses ML to classify sensitive data inside S3. Alerts if PII is in a public bucket.



Artifact = Free Audit Docs

Self-service portal for SOC, ISO, PCI-DSS reports. No new testing required – just download.

Trusted Advisor & Security Hub — Exam Distinctions

AWS Trusted Advisor

Remember the **five pillars** — examiners love asking you to list them:

1. **Cost Optimization**
2. **Security**
3. **Fault Tolerance**
4. **Performance**
5. **Service Limits**

The color system:  Pass /  Investigate /  Act Now.

Basic security checks are available on free accounts. Full checks require Business or Enterprise Support plans.

AWS Security Hub

The exam distinguishes Security Hub by these unique attributes:

- Aggregates findings from **multiple services** into one view
- Provides an overall **security score** for your account
- Runs checks against **CIS Benchmarks** and other standards
- Integrates with third-party security tools beyond AWS
- Enables **automated remediation playbooks**

Practice: Match the Scenario to the Service

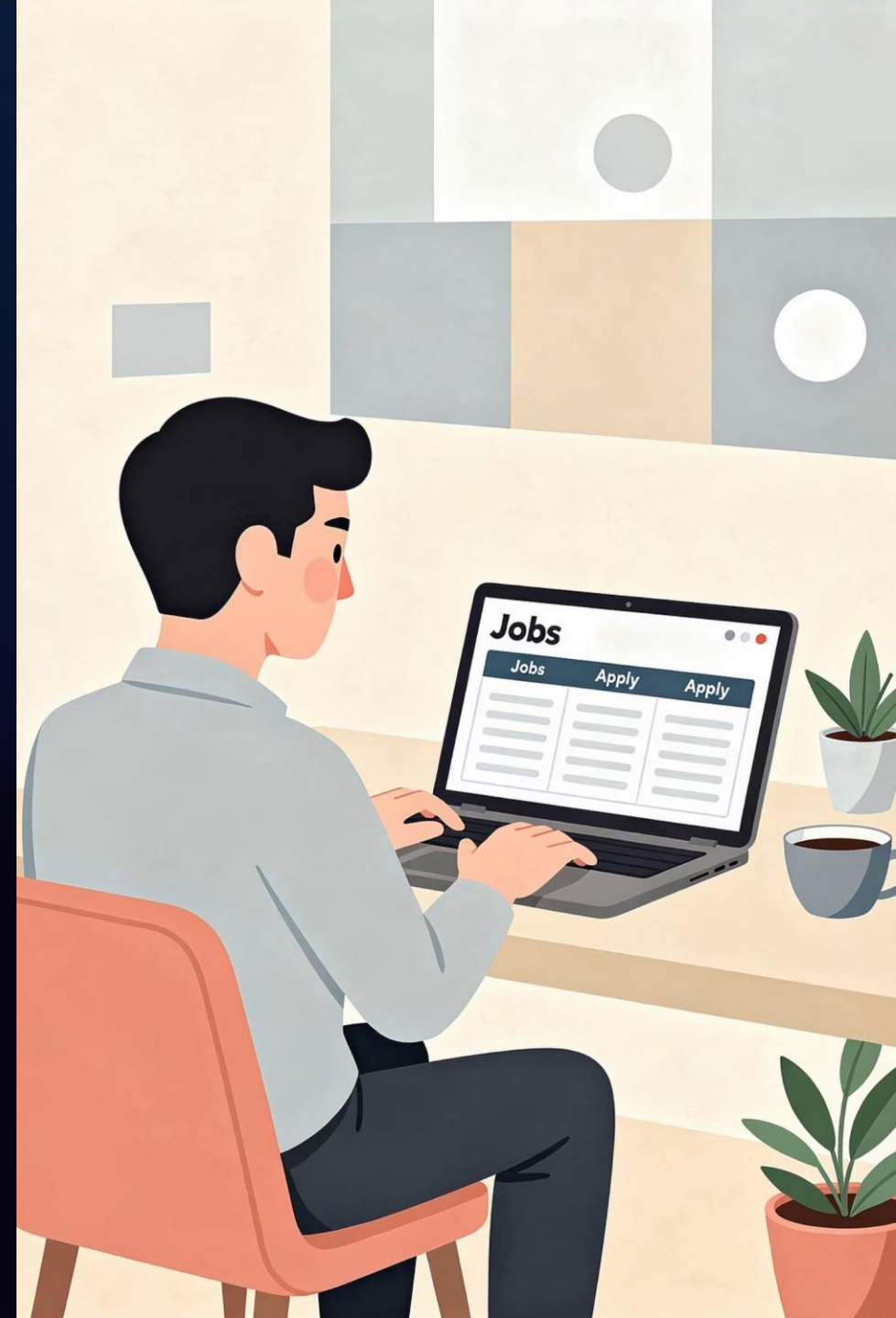
For each situation below, identify which AWS security service is the best primary tool. Cover the right column and test yourself – this is an exam-style drill.

Scenario	Best AWS Service
An EC2 instance is sending traffic to a known malicious IP at 4 AM	Amazon GuardDuty
A developer left SSH port 22 open to 0.0.0.0/0 in a security group	AWS Trusted Advisor
A web app is under a SQL injection attack through a login form	AWS WAF
An auditor needs AWS SOC 2 and ISO 27001 certifications by tomorrow	AWS Artifact
Customer SSNs were uploaded to a public S3 bucket by mistake	Amazon Macie
You need to check all EC2 instances for unpatched software CVEs	AWS Inspector
Your site is getting a massive UDP flood attack from a botnet	AWS Shield
Your security team wants one dashboard with findings from 5 services	AWS Security Hub

Career Connection

These Skills Appear in Real Job Postings — Right Now

The services you learned today are listed by name in entry-level cloud support, cloud operations, and security analyst job postings across the country. You're not learning theory — you're learning the vocabulary and tools that get you hired.



Entry-Level Roles That Use Today's Skills



Cloud Support Associate

Monitors GuardDuty findings, responds to Inspector alerts, and manages WAF rules for client workloads. AWS certifications are often required or preferred. Median salary: \$55K–\$75K to start.



Cloud Security Analyst

Uses Security Hub as the primary daily dashboard, investigates anomalous findings, and coordinates remediation with development teams. AWS Security Specialty or CCP is frequently listed.



IT Compliance Specialist

Leverages AWS Artifact to fulfill audit requests, uses Trusted Advisor to maintain account hygiene, and documents security posture for regulators. Often requires familiarity with HIPAA or PCI-DSS.

Lab Preview: What You'll Do in Today's Hands-On Session

After our break, you will work directly in the AWS console sandbox. Here's exactly what you'll accomplish — skills you can add to your resume today.



Enable Amazon GuardDuty

Activate GuardDuty on your sandbox account and review the threat intelligence dashboard with pre-loaded sample findings



Explore AWS Security Hub

Navigate the Security Hub console, review the CIS Benchmark score, and trace a finding from its source service back to Security Hub



Run Trusted Advisor Checks

Open the Security pillar in Trusted Advisor and document any orange or red flags in your lab worksheet with recommended remediation steps



Download from AWS Artifact

Navigate to AWS Artifact, locate a SOC 2 report, and practice the download workflow you'd use to satisfy a real auditor request

Day 4 Complete — You've Got This!

Today you covered the full spectrum of AWS security — from stopping DDoS floods at the highway to proving compliance in an audit vault. These aren't abstract concepts. They are real tools used by real cloud professionals every single day.

Perimeter

Shield stops floods. WAF stops smart attackers targeting your app code.

Detection

GuardDuty watches behavior. Inspector finds vulnerabilities. Macie protects sensitive data.

Governance

Artifact delivers compliance docs instantly. Trusted Advisor keeps your account healthy.

Command

Security Hub unifies everything into one score, one view, one source of truth.

☐ Take a 15-minute break — when you return, your lab environment will be ready. See you at the console! 🚀

